

# Executive Summary: NIST CSF 2.0 GRC Gap Assessment

Mock assessment for a mid-sized financial services / SaaS organization. This deliverable demonstrates business-facing GRC communication supported by a technical workbook containing control mapping, risk scoring, evidence tracking, and remediation planning.

|                          |                                                                                                                |
|--------------------------|----------------------------------------------------------------------------------------------------------------|
| Assessment lens          | NIST Cybersecurity Framework 2.0 - Govern, Identify, Protect, Detect, Respond, Recover                         |
| Overall current maturity | 2.3 / 5.0 - Developing                                                                                         |
| Target maturity          | 4.0 / 5.0 - Managed                                                                                            |
| Total findings           | 27 open findings across governance, asset management, access control, monitoring, response, and recovery       |
| Highest priority gaps    | Privileged access review, vendor risk, asset ownership, incident response testing, and backup restore evidence |

## Business Readout

The mock organization has a functioning cybersecurity program, but key governance and evidence practices are not yet mature enough to consistently support audit readiness, executive risk decisions, and repeatable incident response. The strongest theme is not a complete absence of controls; it is inconsistent documentation, ownership, review cadence, and proof of operating effectiveness.

The most material risk areas are controls that affect privileged access, third-party exposure, recovery confidence, incident readiness, and visibility across identity, cloud, endpoint, DNS, firewall, and SaaS activity. These gaps should be remediated first because they directly affect the organization's ability to prevent, detect, respond to, and recover from adverse cybersecurity events.

## Top 5 Gaps

| Rank | Gap                                                    | Business risk                                                                       | Recommended action                                                        |
|------|--------------------------------------------------------|-------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| 1    | Privileged access reviews are ad hoc                   | Unauthorized access may persist without detection                                   | Implement quarterly privileged access reviews with retained evidence      |
| 2    | Vendor reviews are inconsistently evidenced            | Critical third-party risk may be missed or accepted informally                      | Create vendor tiering and annual reassessment workflow                    |
| 3    | Asset ownership and criticality tagging are incomplete | Risk decisions may be based on incomplete system context                            | Implement authoritative asset inventory with owner and criticality fields |
| 4    | Incident response plan has not been exercised          | Teams may not execute communications and containment effectively during an incident | Run tabletop exercise and track lessons learned to closure                |
| 5    | Backup restore testing lacks evidence                  | Recovery capability is assumed rather than verified                                 | Perform and document quarterly restore tests for critical systems         |

## 30/60/90-Day Roadmap

| Timeframe | Primary focus                                                                                     | Expected outcome                                                                                |
|-----------|---------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| 30 days   | Approve risk scoring methodology; launch privileged access review; run incident response tabletop | High-risk governance and response gaps move from ad hoc to documented and repeatable            |
| 60 days   | Tag critical assets, build SIEM log coverage matrix, document restore testing process             | Operational owners can show evidence for asset context, monitoring coverage, and recoverability |
| 90 days   | Implement vendor tiering, standardize evidence handling, create recovery communications templates | Program becomes more audit-ready and better aligned to business continuity expectations         |

## Detailed Executive Notes

### Risk Themes

- Governance gaps are concentrated around policy review cadence, risk methodology, roles and responsibilities, and third-party oversight.
- Technical control gaps are most visible in privileged access review, service account governance, asset inventory completeness, SIEM coverage, and cloud configuration evidence.
- Response and recovery gaps are evidence-driven: plans exist, but tabletop testing, after-action tracking, restore testing, and recovery communications need better proof of operation.

### How Leadership Should Use This

Leadership should use the workbook as a control and remediation tracker. The executive dashboard summarizes current maturity, target maturity, open findings, critical/high items, and evidence gaps. The CSF Gap Matrix provides traceability from each finding to risk score, owner, evidence, due date, and remediation plan. The Risk Register translates technical findings into business risk statements and treatment plans.

### Portfolio Skills Demonstrated

| Skill                   | Evidence in deliverable                                                          |
|-------------------------|----------------------------------------------------------------------------------|
| Framework mapping       | Control gaps mapped to NIST CSF 2.0 functions and outcomes                       |
| Risk assessment         | Impact x likelihood scoring, priority assignment, residual risk, treatment plans |
| Audit readiness         | Evidence inventory with frequency, owner, status, storage location, and notes    |
| Remediation planning    | 30/60/90-day roadmap with owner, dependency, success criteria, and status        |
| Executive communication | Concise summary focused on business risk, prioritization, and next steps         |

### Source

NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>

Note: This is a fictional portfolio project. It does not contain confidential data and is intended to demonstrate practical GRC analyst and compliance assessment skills.